

Application Security Development Policy

1. Document Control

1.1 Version History

Date	Document Version	Revision Description	Document Author
11 June 2021	1.1	Initial draft	PwC Consultant
1 June 2022	1.2	Reviewed	Ethan Lam
14 Sep 2026	2.0	Rebranded to Megtech and updated development controls	Security & Compliance Team

1.2 Document Approval

Approver	Title / Role	Approval Date
Executive Management	Managing Director / CISO	Pending Approval

2. Introduction

2.1 Purpose

The Application Security Development Policy ("this policy") is established to ensure security is an integral component of information systems across the entire development lifecycle, and to isolate development, testing,

and production environments to minimize operational and security risks. This policy defines baseline requirements; the implementation of stricter controls than those stated herein is encouraged.

2.2 Scope

This policy applies to Megtech and its affiliates involved in application development. All employees, contractors, and third-party service providers who conduct application development for or on behalf of Megtech must comply with this policy.

3. Roles and Responsibilities

Stakeholder	Responsibility
Product Manager / Department Head	Monitor the application development lifecycle to ensure Megtech security and compliance requirements are achieved.
Developer / Engineering Personnel	Understand secure development obligations and execute the technical provisions defined in this po

4. Security in Acquisition, Development, and Support

Security and privacy by design must be integrated from project conception through decommissioning for all new applications and major system modifications.

4.1 System Specification and Design Control

Prior to development, security specifications must be defined, assessed, and agreed upon between engineering teams and the Cybersecurity / Information Security Team. Security objectives concerning confidentiality, integrity, and availability must be formally documented.

Architectural and design reviews must incorporate the following principles:

- Principle of least privilege
-
- Segregation of duties
-
- Robust authentication and authorization frameworks
-
- Strict input validation and sanitization
-
- Data confidentiality and field-level encryption
-
- Removal of unnecessary services, dependencies, and debug interfaces
-
- Centralized log management and audit readiness
-

4.2 Secure Development Requirements

System architecture documentation, source code repositories, and application component listings must be documented, maintained, and restricted on a need-to-know basis. Secure development standards must be reviewed regularly.

Core controls include:

- Strict isolation between development, testing/staging, and production environments.
-
- Separation of access: developers with access to development environments must not possess production access unless formally authorized through approved change-management protocols.
-
- Version control systems must be enforced for all codebases to provide auditable commit histories and program rollback capabilities.
-
- Minimization of Personally Identifiable Information (PII) processing across non-production environments.
-
- Mandatory application security, data privacy, and secure coding training for development personnel.
-
- Dedicated protection and masking when live production configurations or data structures are handled outside production environments.
-
- For public-facing services:
-
- Prior risk assessment before transmitting application services or data across public networks.
-

- Identity authentication and strong transport-layer encryption applied before and during data transmission over untrusted networks.

-
- End-to-end encrypted communication paths using secure, modern protocols.

-

4.3 Secure Code Management

- Source code repositories must reside in secured infrastructure segregated from runtime production environments.

-

- Access permissions to source code repositories must follow least privilege and role-based access controls.

-

- Code modifications must strictly adhere to formal change management workflows (e.g., peer reviews, pull-request approvals).

-

- All repository actions (read, write, merge, branch modifications) must be logged, with logs audited periodically for unauthorized activity.

-

- Static Application Security Testing (SAST) and manual peer reviews must be executed during active development to remediate flaws before merge.

-

4.4 Outsourced Development

When application development is outsourced to external vendors or contractors:

- Formal vendor due diligence must be completed and documented.

-

- External development activities must be supervised and validated against Megtech's internal security policies.

-

- System access must be restricted to a need-to-know basis and subjected to continuous access monitoring.

-

- Third-party deliverables must be formally verified against Megtech information security baselines prior to acceptance.

-

- Outsource partners must adhere to Megtech internal security practices, including personnel vetting and security awareness obligations.

-

5. Test and Review of Security Measures

New systems and major revisions must undergo documented user and security acceptance testing before promotion to production. Test plans must encompass core functionalities, interfaces, system dependencies, and process logic.

Automated vulnerability scanning, Software Composition Analysis (SCA), dynamic testing (DAST), penetration testing, and code reviews must be executed prior to production release. Identified vulnerabilities must be remediated according to severity thresholds prior to deployment.

Code and system reviews must verify:

- Data in transit is encrypted with current TLS standards, and sensitive data at rest uses approved encryption algorithms.
-
- Authentication controls are correctly implemented, including password parameters, hashing, and credential isolation.
-
- Authorization mechanisms strictly enforce least privilege across all user roles and APIs.
-
- Error handling is sanitized to avoid leaking sensitive internal system details or stack traces.
-
- Sensitive business, transactional, and personal data are stored securely.
-
- No credentials, API tokens, or secrets are hardcoded or committed to version control repositories.
-

5.1 Test Data

- Real PII must not be utilized in development or testing; data must be anonymized, synthetic, or de-personalized prior to use.
-
- Unsanitized production data is strictly prohibited from non-production environments unless documented business justification and formal approval are obtained.
-
- Sensitive data attributes must be removed or masked prior to testing.
-
- Test datasets must be securely purged upon test completion.
-

6. Review of this Policy

This policy must be reviewed at least annually to maintain alignment with evolving technologies, development workflows, and applicable legislative or regulatory requirements.